第 15 章練習　安全

> 本檔只含題目。請先自行建立狀態或變數表，再作答；解答在獨立檔案。

OS15-E01　越界與防禦邊界

容量12-byte的C字串目的buffer，輸入data長12；本題不假設實際ABI配置。

1. 連NUL完整複製需要幾bytes？兩種正確契約如何處理？
2. NX可否阻止此次越界？

OS15-E02　DoS 的 pending slots

有2000 slots，每筆未完成請求保留8 s，無提前清除。

1. 以相同觀測邊界估占滿slots的平均到達率。
2. 按source IP限制可能傷害誰？

OS15-E03　重用 keystream

m1=0x10，m2=0x70，s=0xA5，c=m XOR s。

1. 算兩ciphertexts、其XOR，已知m1如何解m2？
2. 此推理是否依賴暴力破解cipher？

OS15-E04　RSA 的非互質明文

p=5、q=11、n55、e3、d27；令m=5。

1. 算cipher與decrypt並列平方表。
2. 因gcd(5,55)≠1，為何仍正確？

OS15-E05　MAC、hash 與 replay

接收方收到(m,H(m))，或(m,MACk(m))，或nonce-bound MAC。

1. 為何公開hash不能認證？MAC又為何不自動防重放？
2. 兩個thread同時驗到pending nonce，如何避免雙接受？

OS15-E06　歷史 TLS 的身分與forward secrecy

TLS1.2 RSA full handshake，網路對手可錄封包；兩年後server的static RSA private key外洩。

1. certificate簽章有效是否足以當下確認server持private key？
2. 先前錄到的session是否因已刪traffic key就必然安全？

第 15 章練習　安全 （續）

OS15-E07　Salt 與猜測成本

500筆各有不同salt；每筆字典20000候選；KDF每次2 ms，單一工作單元串行。

1. 完整字典最多需幾次KDF、多少時間？salt是否秘密？
2. online每帳號每秒一次的limit是否把上述offline時間改成10000000 s？

OS15-E08　IDS 的 base rate

100000事件，攻擊比例0.001；TPR0.9，FPR0.01。

1. 列expected TP/FN/FP/TN與precision。
2. 固定TPR與base rate，要precision至少50%，FPR應≤多少？

OS15-E09　Firewall 真正允許什麼

採正文first-match policy與三個zones；只列established、Internet→web443、web→DB5432，最後deny。

1. 判Internet→DB5432、web→DB5432、web→DB22與既存DB→web回應。
2. web遭入侵後是否不能觸DB？

OS15-E10　Windows7 ordered DACL 與 MIC

普通specific read/write masks，無privilege/owner等例外；token U在G且IL=low；物件IL=medium，policy NO_WRITE_UP。

1. DACL=[deny(G,w),allow(U,rw)]，request r與rw分別如何？
2. 把allow U,rw刻意放前，DACL對rw如何？最終write又如何？
3. NULL DACL與empty DACL如何不同？

參考資料與署名

Abraham Silberschatz, Peter B. Galvin, Greg Gagne. Operating System Concepts, 9th Edition.

Lin Cing 原創教學整理。原創內容以 CC BY 4.0 授權；參考書籍不隨教材散布。
https://github.com/xinhi6716/computer-science-self-study